Digital Forensics & Incident Response Playbook Documentation

Team Members:

Manar Nasser

Abanoub Rofaeil

Menna Sabek

Marwan Amin

Eng / Marwan El Sayyad

Project Overview

The purpose of this project is to build a complete Incident Response and Digital Forensics (DFIR) Playbook focused on phishing attacks, including advanced scenarios like EvilProxy attacks. The project covers the full incident response lifecycle, from preparation and team setup to post-incident review and lessons learned.

The project aims to simulate real-world scenarios, develop policies, and create structured procedures for detecting, analyzing, containing, eradicating, and recovering from phishing incidents.

Week 1 – Incident Preparation & Team Setup

During the first week, our team focused on **preparing for incident response**. Key activities included:

- **Developing Incident Response Policies:** Defined the purpose, scope, incident types, reporting procedures, and policy review cycle.
- **Setting up the Incident Response Team (IRT):** Assigned roles including CTI, EDR, Threat Hunting, L1 & L2 Analysts, and DFIR team members. Responsibilities and example tasks were documented.
- **Creating a Communication Plan:** Established the escalation flow from users reporting suspicious activity to management notification, including procedures for external communication.
- **Preparing an Incident Response Checklist:** Listed all tools, monitoring, logging, and employee readiness steps required before an incident occurs.
- **Designing an IR Playbook Template:** Structured the incident response process into phases: Preparation, Detection, Containment, Eradication, Recovery, and Post-Incident Review.

Research and Brainstorming:

In parallel, the team conducted **research on phishing attacks**, exploring publicly available playbooks and guidelines to understand best practices in detection, containment, and recovery.

We performed **brainstorming sessions** to align on strategies, assign tasks, and refine the steps required for our phishing simulation. This ensured that all team members understood their roles and responsibilities within the playbook framework.

Simulation Planning :

Based on our research and preparation, we began planning the **phishing simulation**:

- Identified potential phishing scenarios and selected a test scenario suitable for the team's simulation.
- Defined objectives for each team role (CTI, EDR, Threat Hunting, L1/L2 Analysts, DFIR).
- Prepared supporting tools and resources to simulate incident detection and evidence collection.
- Documented expected outputs, including **incident logs, evidence files, timelines, and recovery steps**.

Deliverables Completed

At the end of Week 1, the following deliverables were completed:

1. **IR_Policy.docx** – containing the incident response policy, reporting guidelines, evidence handling, communication and escalation procedures, and policy review.
2. **IRT_Roles.docx** – detailed team roles and responsibilities for all DFIR team members.
3. **Communication_Plan.docx** – defined reporting and escalation pathways.
4. **IR_Checklist.docx** – preparation checklist for phishing incident readiness.
5. **IR_Playbook_Template.docx** – structured incident response steps ready for execution.

Reflection :

During this phase of the project, we learned the importance of **preparation in incident response**. Clearly defined roles, policies, and communication channels are essential to respond effectively to phishing incidents.

The research and brainstorming sessions highlighted how real-world attackers, such as EvilProxy campaigns, operate and the types of logs and indicators needed for detection.

This groundwork sets the foundation for the **next phases**, including incident simulation, evidence collection, containment, and post-incident review.

Supporting Materials:

- Include copies of the documents: IR_Policy, IRT Roles, Communication Plan, Checklist, and Playbook Template.

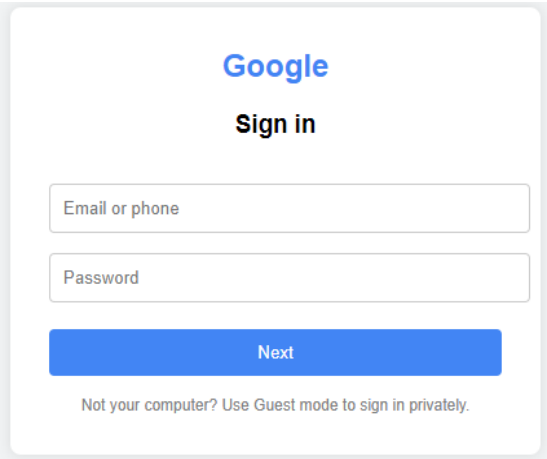
وزارة الاتصالات
وتكنولوجيا المعلومات

واد مصر الرقمية

week 2: Incident Simulation & Evidence Collection

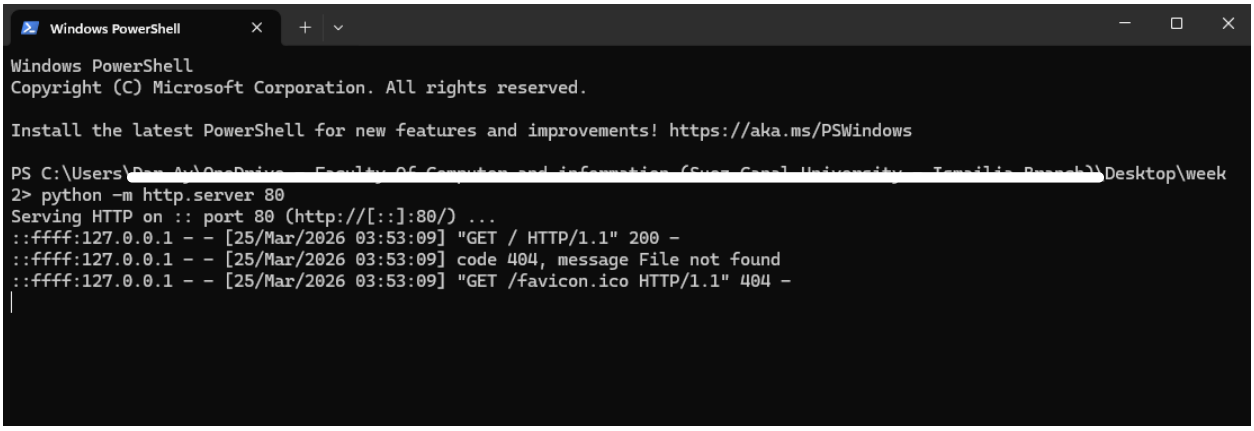
Incident Simulation

A phishing attack scenario was simulated by creating a fake login page designed to mimic a legitimate service. The page was developed using HTML and styled to resemble a trusted login interface.

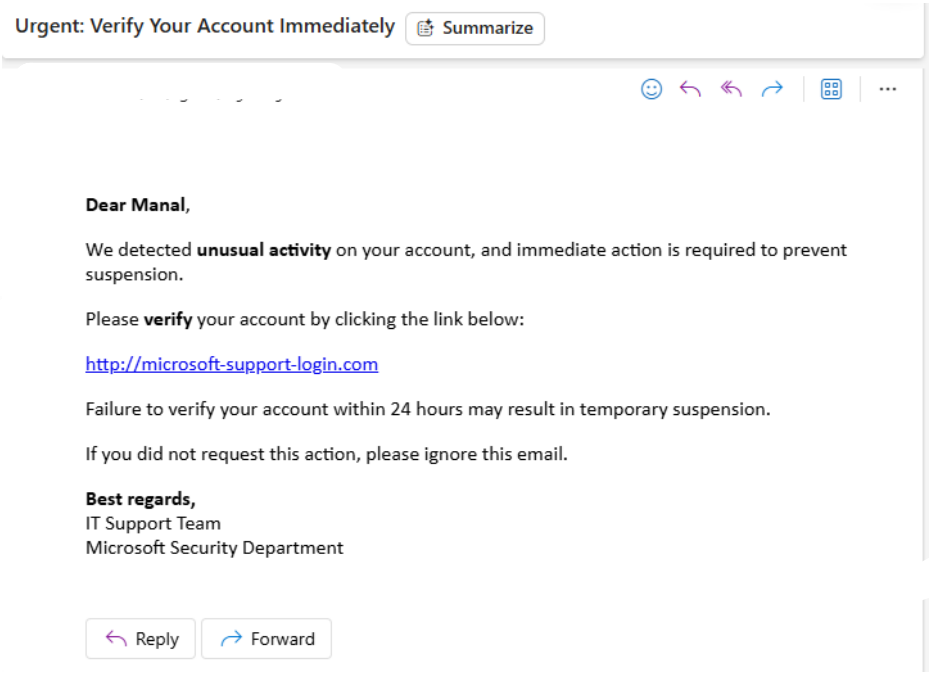



```html
<!DOCTYPE html>
<html lang="en">

<head>
    <meta charset="UTF-8">
    <title>Sign in - Google Accounts</title>

    <style>...
    </style>
</head>

<body>

    <div class="container">
        <div class="logo">Google</div>
        <h3>Sign in</h3>

        <form onsubmit="saveData(event)">
            <input type="text" id="email" placeholder="Email or phone" required>
            <input type="password" id="password" placeholder="Password" required>
            <button type="submit">Next</button>
        </form>

        <div class="footer">
            Not your computer? Use Guest mode to sign in privately.
        </div>
    </div>

    <script>
        function saveData(event) {
            event.preventDefault();

            let email = document.getElementById("email").value;
            let password = document.getElementById("password").value;

            // حفظ البيانات locally (Simulation فقط)
            localStorage.setItem("phishing_email", email);
            localStorage.setItem("phishing_password", password);

            // عرض رسالة للمستخدم
            alert("Session expired. Please try again.");

            // طباعة في console (Evidence)
            console.log("Captured Email:", email);
            console.log("Captured Password:", password);
        }
    </script>

</body>
```

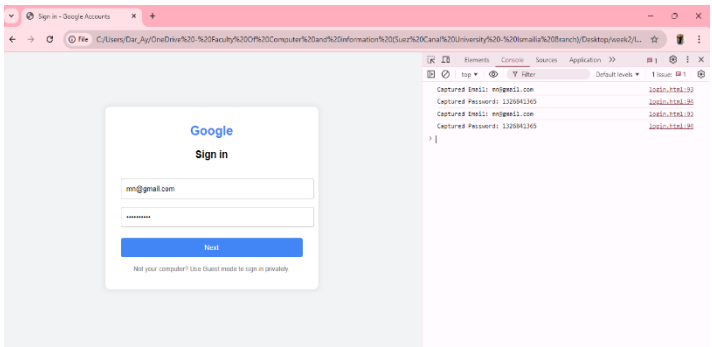
To enhance realism, a **spoofed domain** was configured locally by modifying the system hosts file. The domain microsoft-support-login.com
was mapped to the local machine (127.0.0.1), allowing the phishing page to be accessed as if it were a real website.

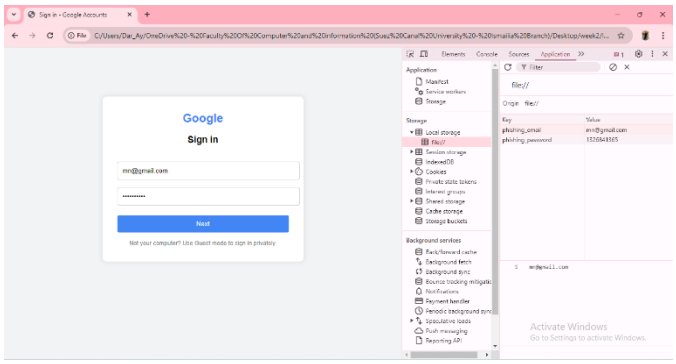


A phishing email was also created, containing a malicious link that directs the user to the fake login page. The email used urgency and impersonation techniques to deceive the user.



The user interaction was simulated by opening the phishing link (http://microsoft-support-login.com) and entering fake credentials (email and password), representing a successful phishing attempt.



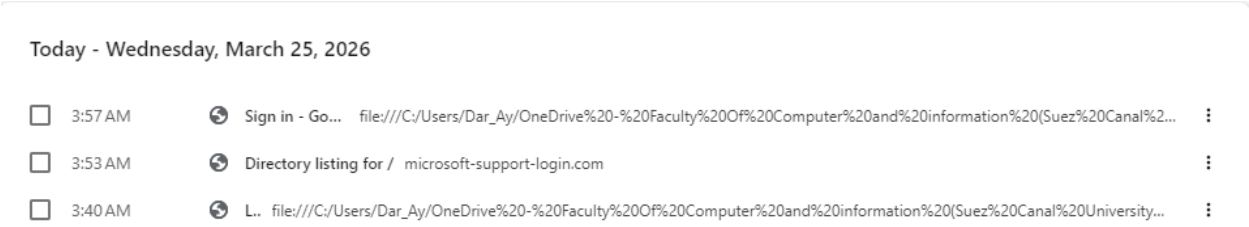


.

Evidence Collection

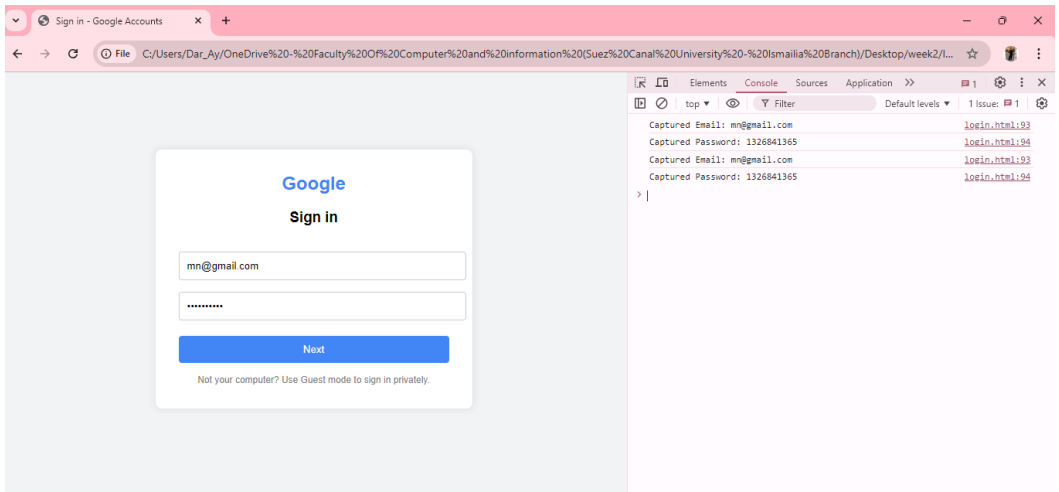
During the simulation, multiple types of digital evidence were collected:

- **Browser History:**
  The spoofed domain (microsoft-support-login.com) was recorded in the browser history along with the access timestamp.



- **Local Storage Data:**
  User credentials entered into the phishing page were stored locally in the browser, demonstrating how attackers can capture sensitive information.

- **Console Logs:**
  The captured credentials were displayed in the browser console, providing additional evidence of data capture.



- **Screenshots:**
  Screenshots were taken of the phishing page, the spoofed domain in the browser URL bar, and stored data to document the incident.

Incident Timeline

Time	Event Description	Evidence
12:00 AM	Phishing email was received	Email content
03:40 AM	User accessed local phishing file (login.html)	Browser History
03:53 AM	Spoofed domain (microsoft-support-login.com) accessed	Browser History
03:57 AM	Fake Google login page opened	Screenshot
03:58 AM	User entered email and password	Phishing Page
03:58 AM	Credentials captured and displayed in console	Console Logs

Analysis

The simulation demonstrated a phishing attack using a **domain spoofing technique**, where a fake domain resembling a legitimate service was used to deceive the user.

The domain **microsoft-support-login.com** appears visually similar to a trusted domain, increasing the likelihood of user interaction.

This highlights how attackers exploit domain similarity and social engineering techniques to capture sensitive information.

The collected evidence confirms that the user accessed the spoofed domain and that credentials were successfully captured.

Week 3: Containment, Eradication, and Recovery

Root Cause Analysis (RCA):

- analyzed the attack vector and confirmed it was a **Credential Harvesting** attack via **DNS Poisoning**.
- The root cause was identified as a lack of email filtering and a vulnerability in system permissions that allowed modifying the hosts file.

```
# localhost name resolution is handled within DNS itself.
#       127.0.0.1       localhost
#       ::1             localhost
```

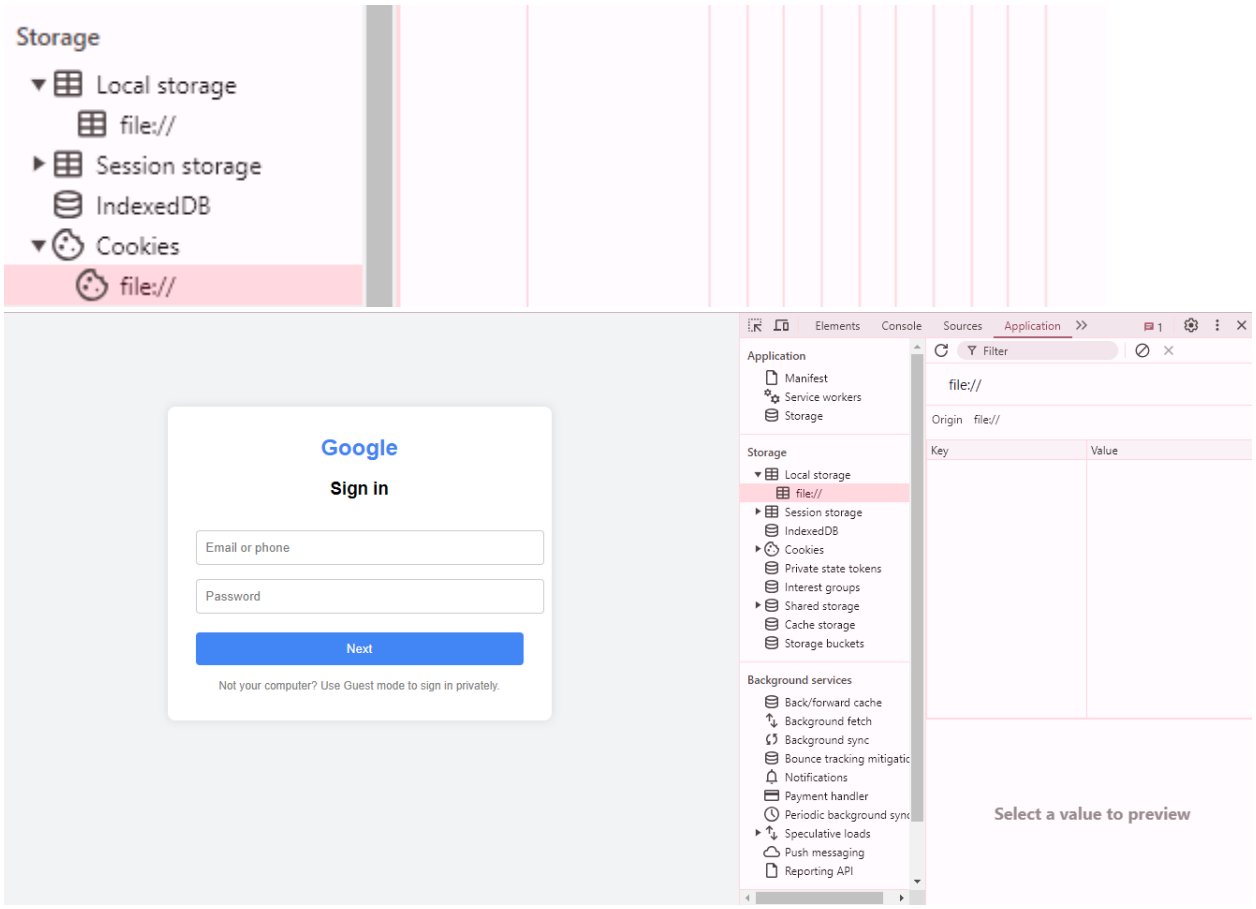
```
# localhost name resolution is handled within DNS itself.
#       127.0.0.1       localhost
#       ::1             localhost
127.0.0.1   microsoft-support-login.com
```

Containment:

- simulated the isolation of the affected workstation to prevent further communication with the malicious domain **microsoft-support-login.com**.
- identified the need to revoke active sessions to stop the attacker from using the captured tokens.

Eradication (Technical Cleanup):

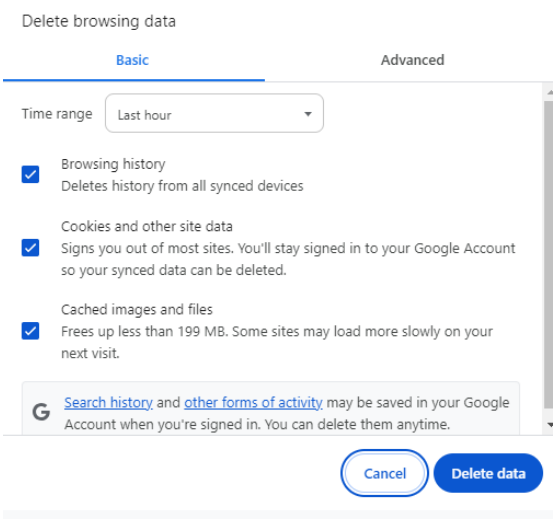
- **Manual DNS Fix:** accessed the system path C:\Windows\System32\drivers\etc\hosts and removed the malicious IP mapping to stop the redirection.
- **Browser Sanitization:** performed a deep clean of the browser by clearing the **History, Cache, and Cookies**.

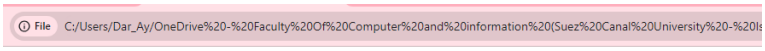


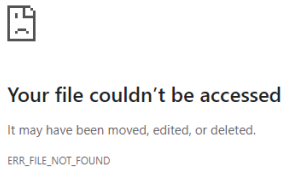
- **Forensic Wipe:** used **Developer Tools (F12)** to manually wipe the **Local Storage** where the phishing script stored the stolen data.

Recovery:

- restored the browser to its default settings to ensure no malicious extensions remained.
- verified that the user "Manal" could no longer be redirected to the fake page and ensured the system was ready for a secure password reset.







Week 4: Post-Incident Activities

Lessons Learned Session:

- conducted a review of the incident and concluded that User Awareness Training is the most critical defense against social engineering.

- I identified that restricting administrative access to system files (like the hosts file) would have prevented this specific attack.

Final Documentation & Reporting:

- Technical Report: compiled all the digital evidence, including the Incident Timeline (from email receipt at 12:00 AM to credential capture at 03:58 AM) and the Console Logs showing the stolen email and password.

- Executive Presentation: I prepared a summary of the key findings, focusing on the speed of response (12 minutes from detection to containment) and the resolution steps.

Final Recommendations:

documented the necessity of implementing Multi-Factor Authentication (MFA) and advanced email security gateways to block spoofed domains in the future